

KESTRELATTICE

Governed Agent Mesh | Micro-Product

Customer-Facing Runbook Excerpt

Incident

When an agent incident reaches customers: triage, message, remediate, and follow up. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

Customer-Facing Incident Runbook Excerpt

For AI Agents in Production Version 1.0 | Last Updated: [MM/DD/YYYY] Owner: [Incident Response Team] | Approved by: [Chief Risk Officer / CISO]

1. SCOPE

This runbook governs **customer-facing incidents** involving AI agents deployed in production, including but not limited to: - **Data breaches or leaks** (e.g., PII exposure via agent responses). - **Hallucinations or misinformation** (e.g., incorrect factual claims affecting business decisions). - **Bias or discriminatory outputs** (e.g., agent responses violating fairness policies). - **Compliance violations** (e.g., GDPR, CCPA, or sector-specific regulations). - **Systemic failures** (e.g., agent refusal loops, catastrophic cost spikes, or API throttling). - **Third-party integrations failures** (e.g., payment processing errors, CRM miscommunications).

Applies to: - All AI agents with direct customer interaction (chatbots, virtual assistants, generative copilots). - Agents embedded in SaaS platforms, marketplaces, or customer support workflows. - Agents with **customer-facing APIs** (e.g., generate_response(), recommend_product()).

Excludes: - Internal-only agents (e.g., developer tooling, HR onboarding assistants). - Non-production environments (staging, sandbox).

2. POLICY GATES & PRE-INCIDENT CONTROLS

Before an incident escalates, the following safeguards must be in place:

2.1 Permissioning & Access Controls

Control	Implementation	Audit Field
Agent Deployment Approval	Requires multi-signoff (Product Owner, Security, Compliance) before go-live.	deployment_approval_log
Customer Interaction Flag	Agents with customer_facing=true in config must pass red-team testing.	customer_facing_flag_review
Role-Based Access	Only Incident Commanders (ICs) and Escalation Leads can trigger incident workflows.	role_based_access_log
API Key Rotation	Customer-facing agent keys rotated every 72 hours; audit trails required.	api_key_rotation_audit

2.2 Real-Time Monitoring & Alerting

Monitoring Rule	Threshold / Trigger	Remediation Action
Hallucination Rate	> 1.2% of customer interactions (baseline: 0.8% from historical data).	Deploy fallback response module.
Bias Flagging	Fairness score < 0.9 (using IBM AI Fairness 360).	Trigger bias mitigation review.
Cost Anomaly	> 150% of 95th percentile spend in a 1-hour window.	Enforce rate limiting.
Data Leakage	PII detected in agent output (via OpenPII).	Immediate blacklist customer data.

Tools: - **Incident Detection:** [Datadog](#) + custom LLM monitoring (e.g., [LangSmith](#)). - **Audit Logs:** [AWS CloudTrail](#) for API calls, [Databricks Unity Catalog](#) for data access.

3. INCIDENT RESPONSE PHASES

3.1 Detection & Initial Assessment

Trigger: - **Automated alert** (via monitoring tools) **OR** - **Customer complaint** (via support ticket, social media, or direct message).

Steps: 1. **IC Designation:** - Assign an **Incident Commander (IC)** from the **AI Governance Team**. - IC must confirm incident **scope** (e.g., "Hallucination in Product Recommendations") and **impact** (e.g., "High: 500+ customer complaints").

1. **Initial Containment:**
2. **Disable affected agent** (via feature flag) if:
 - Data breach risk.
 - Compliance violation confirmed.

Isolate customer data if PII exposure detected.

First Notification:

5. **Internal:** Escalate to **Legal, PR, and Engineering Leads**.
6. **External (if applicable):**
 - **High-severity incidents** (e.g., GDPR breach) -> **Regulatory notification within 72 hours** (per [GDPR Art. 33](#)).
 - **Customer communication template** (see **Appendix A**).

3.2 Investigation & Root Cause Analysis (RCA)

Tools Required: - **Agent Logs:** [Vector](#) or [Elasticsearch](#) for conversation history. - **Model Audit:** [Hugging Face Model Cards](#) + custom prompt analysis. - **Cost Tracking:** [GCP Billing Reports](#) or [AWS Cost Explorer](#).

RCA Framework: | **Root Cause Category** | **Likely Triggers** | **Evidence to Collect** |
 -----|-----
 -----| | **Data Quality** | Training data bias, outdated knowledge cutoff. | dataset_version, training_data_sources. | | **Prompt Engineering** | Ambiguous user intents, lack of guardrails. | user_prompt_logs, response_generation_rules. | | **Systemic Failures** | API rate limits, model degradation. | api_call_logs, model_performance_metrics. | | **Permission Misconfig** | Overprivileged agent roles (e.g., admin access). | rbac_audit_logs. | | **Third-Party Risks** | Integrations with unvetted

APIs (e.g., payment processors). | integration_contract_review. |

Deliverable: - **RCA Report** (template in **Appendix B**) due **within 48 hours** of incident declaration.

3.3 Containment & Recovery

Containment Strategies: | **Incident Type** | **Containment Action** | **Validation Check** |

-----|-----|-----|-----|
| **Hallucination** | Deploy **fallback to structured knowledge base** (e.g., RAG + vector DB). | fallback_accuracy > 90% (A/B test). | | **Bias Exposure** | Redact sensitive attributes; retrain with **fairness-aware sampling**. | bias_score > 0.95 post-mitigation. | | **Cost Spiral** | Enforce **token budget caps** (e.g., 1,000 tokens/user interaction). | cost_reduction > 30%. | | **Data Leak** | **Purge exposed data** from training sets; notify affected customers. | compliance_check_passed (e.g., GDPR). | | **API Failure** | Switch to **secondary provider** (e.g., Mistral -> Llama 2). | uptime_sla_restored. |

Recovery Timeline: | **Phase** | **Timeframe** | **Owner** | **Deliverable** |

-----|-----|-----|-----|-----|
| **Temporary Fix** | < 24h | DevOps | Functional workaround deployed. | | **Permanent Fix** | < 72h | AI Governance Team | RCA-approved code changes merged. | | **Post-Mortem** | < 5 days | IC + Cross-Functional Team | **Incident Playbook Update** (see below). |

3.4 Post-Incident Review & Playbook Update

Required Actions: 1. **Root Cause Confirmed:** - Document in **Jira ticket** (template: AI-<INCIDENT_ID>-RCA). - Assign **technical debt** to relevant teams (e.g., "Upgrade prompt validation").

1. **Playbook Update:**
2. **Add new detection rules** (e.g., "Alert on bias in loan approval recommendations").
3. **Update response templates** (e.g., "Customer data leak notification").

Revise permissioning (e.g., "Restrict agent access to payment APIs").

Training:

6. **Incident drills for customer support teams** (quarterly).
7. **AI ethics training** for engineers (annual).

Audit Trail: - All changes logged in **GitHub PRs** with **approvals** and **impact analysis**. - **Incident Playbook version bumped** in **Confluence**.

4. COST & RESOURCE CONTROLS

Control	Implementation	Audit Field
Token Budgeting	Enforce hard limits (e.g., 500 tokens/response) via API gateway.	token_spend_audit.
Model Swapping	Allow fallback to cheaper models (e.g., Mistral Tiny -> Mistral Large).	cost_optimization_logs.
Customer Charging	Cap usage-based fees (e.g., "No charge for hallucinations").	billing_dispute_resolution.
Incident Budget	Allocate \$X per incident (e.g., \$50K for GDPR breach) from AI Governance Fund.	incident_fund_allocation.

Example Cost Escalation Path: 1. < \$10K: Team self-funds. 2. \$10K-\$100K: Escalates to VP of Engineering. 3. > \$100K: Requires Board approval.

5. COMPLIANCE & AUDIT REQUIREMENTS

5.1 Regulatory Alignment

Regulation	Requirement	Evidence
GDPR (Art. 32)	"Ensure the integrity and confidentiality of processing."	data_processing_audit.
CCPA	"Right to deletion" for customer data exposed in	

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com